Polityka Bezpieczenstwa Informacji

Wersja 4.0 | Styczen 2025 | Dokument obowiazujacy

Numer dokumentu:	PBI-2025-4.0
Autor:	Michal Jankowski – CISO / Dzial IT
Zatwierdzone przez:	Zarzad LUCIDEXIS Sp. z o.o.
Data zatwierdzenia:	02.01.2025
Kolejny przeglad:	02.01.2026
Klasyfikacja:	WEWNETRZNA
Zastepuje wersje:	PBI-2024-3.1 z dnia 01.07.2024

LUCIDEXIS Sp. z o.o. | ul. Gdanska 14/3, 81-339 Gdynia | biuro@lucidexis.pl | www.lucidexis.pl

SPIS TRESCI

1.	**Cel i zakres dokumentu**	3
2.	**Definicje i skroty**	3
3.	**Klasyfikacja informacji**	4
3.1.	Kategorie danych	4
3.2.	Zasady oznaczania dokumentow	4
4.	**Zarzadzanie dostepem**	5
4.1.	Zasady przyznawania uprawnie	5
4.2.	Uwierzytelnianie i hasla	5
4.3.	Dostep zdalny i VPN	5
5.	**Bezpieczenstwo urzadzen i infrastruktury**	6
5.1.	Urzadzenia firmowe	6
5.2.	BYOD – urzadzenia prywatne	6
5.3.	Siec firmowa i Wi-Fi	6
6.	**Ochrona danych osobowych (RODO)**	7
7.	**Bezpieczenstwo poczty i komunikacji**	7
8.	**Zarzadzanie incydentami**	8
9.	**Kopie zapasowe i ciaglosc dzialania**	8
10.	**Audyt i monitorowanie**	9
11.	**Szkolenia i swiadomosc**	9
12.	**Kary i odpowiedzialnosc**	9
13.	**Historia zmian**	10

1. CEL I ZAKRES DOKUMENTU

Niniejsza Polityka Bezpieczenstwa Informacji (dalej: PBI) okresla zasady, standardy i wymagania dotyczace ochrony informacji w firmie LUCIDEXIS Sp. z o.o. (dalej: Firma). Glownym celem PBI jest zapewnienie poufnosci, integralnosci i dostepnosci (triada CIA) informacji przetwarzanych w Firmie, niezaleznie od formy ich przechowywania – elektronicznej, papierowej lub ustnej.

Dokument obowiazuje wszystkich pracownikow zatrudnionych na podstawie umowy o prace, umowy zlecenia lub umowy o dzielo, a takze zewnetrznych dostawcow, partnerow i podwykonawcow, ktorym przyznano dostep do systemow lub danych Firmy. Nieprzestrzeganie postanowien PBI moze skutkowac konsekwencjami dyscyplinarnymi i prawnymi opisanymi w rozdziale 12.

Podstawy prawne

Rozp. Parlamentu Europ. 2016/679 (RODO) | Ustawa o ochronie danych osobowych z 10.05.2018 | Ustawa o krajowym systemie cyberbezpieczenstwa z 05.07.2018 | ISO/IEC 27001:2022

2. DEFINICJE I SKROTY

Pojecie / Skrot	Definicja
CIA	Confidentiality, Integrity, Availability – triada bezpieczenstwa informacji
CISO	Chief Information Security Officer – Wlasciciel niniejszej polityki
2FA / MFA	Uwierzytelnianie dwu-/wieloskladnikowe
VPN	Virtual Private Network – szyfrowany tunel sieciowy
BYOD	Bring Your Own Device – uzywanie prywatnych urzadzen do celow sluzbowych
MDM	Mobile Device Management – system zarzadzania urzadzeniami mobilnymi
Incydent	Zdarzenie naruszajace lub zagradzajace poufnosc, integralnosc lub dostepnosc danych
PII	Personally Identifiable Information – dane umozliwiajace identyfikacje osoby
DLP	Data Loss Prevention – system zapobiegania wyciekom danych
SLA	Service Level Agreement – umowa o poziomie uslug
RTO	Recovery Time Objective – maks. czas przywrocenia systemow po awarii
RPO	Recovery Point Objective – maks. akceptowalna utrata danych (w czasie)

3. KLASYFIKACJA INFORMACJI

3.1 Kategorie danych

Wszystkie informacje przetwarzane w Firmie sa klasyfikowane wedlug ponizszego schematu. Klasyfikacji dokonuje wlasciciel danych lub osoba przez niego upowazniona. W przypadku watpliwosci domyslna klasyfikacja to WEWNETRZNA.

Kategoria	Opis	Przyklady	Dostep
TAJNE	Inf. kluczowe dla dzial. firm	Strategie, plany M&A, kody zrodlo	Zarzad + CISO
POUFNE	Dane osobowe, finansowe	Wynagrodzenia, dane klientow, N	Upowaznieni
WEWNETRZNA	Dok. operacyjne, procedu	Regulaminy, harmonogramy, rapo	Wszyscy pracownicy
PUBLICZNA	Materialy zatwierdzone do	Oferty, press release, strona www	Bez ograniczen

3.2 Zasady oznaczania dokumentow

Kazdy dokument elektroniczny lub papierowy zaklasyfikowany jako POUFNY lub TAJNY musi byc oznaczony widocznym znacznikiem w naglowku lub stopce. Dokumenty elektroniczne nalezy oznaczac za pomoca metadanych w systemach Confluence i SharePoint. Wydruki dokumentow POUFNYCH i TAJNYCH musza byc przechowywane w zamknietych szafach i niszczone niszczarka dokumentow (klasa P-4 lub wyzsza).

- Dokumenty TAJNE: czerwony naglowek "TAJNE – TYLKO DO WIADMOSCI ADRESATA"
- Dokumenty POUFNE: pomaranczowy naglowek "POUFNE – WEWNETRZNE UZYCIE"
- Dokumenty WEWNETRZNE: szary naglowek "WEWNETRZNE – NIE UDOSTEPNIAC NA ZEWNATRZ"
- Dokumenty PUBLICZNE: brak oznaczenia (domyslnie jawne)

Wazne – niszczenie dokumentow

Dokumenty POUFNE i TAJNE w wersji papierowej musza byc niszczone niszczarka o klasie co najmniej P-4 (paskowanie krzyzowe, czastki < 160 mm²). Wrzucanie do kosza na smieci jest surowo zabronione i stanowi incydent bezpieczenstwa. Raz w miesiącu organizowana jest akcja "czyszczenia biurek" – obowiazkowe uczestnictwo wszystkich pracownikow.

4. ZARZADZANIE DOSTEPEM

4.1 Zasady przyznawania uprawnie

Dostep do systemow informatycznych i danych Firmy jest przyznawany zgodnie z zasada najmniejszych uprawnie (Principle of Least Privilege). Oznacza to, ze kazdy uzytkownik otrzymuje wylacznie te uprawnienia, ktore sa niezbedne do wykonywania jego obowiazkow sluzbowych. Wszelkie wnioski o dostep musza byc zatwierdzane przez bezposredniego przelozonego oraz Dzial IT.

1. Wniosek o dostep sklada pracownik lub jego przelozony przez portal IT (it.lucidexis.pl/dostep)
2. Dzial IT weryfikuje zasadnosc wniosku w ciagu 2 dni roboczych
3. Dostep jest przyznawany na czas okreslony (max. 12 miesiecy) lub do konca zatrudnienia
4. Corocznie przeprowadzany jest przeglad uprawnien (Access Review) przez CISO
5. Po zakonczeniu wspolpracy dostep jest cofany w ciagu 24 godzin od rozwiazania umowy

4.2 Uwierzytelnianie i hasla

Wszystkie systemy Firmy wymagaja uwierzytelnienia. Dla danych POUFNYCH i TAJNYCH obowiazkowe jest uwierzytelnianie wieloskladnikowe (MFA). Ponizej przedstawiono wymagania dotyczace hasel obowiazujace od 01.01.2025:

Parametr	Wymaganie
Minimalna dlugosc hasla	14 znakow
Zlozonosc	Min. 1 wielka litera, 1 mala litera, 1 cyfra, 1 znak specjalny
Waznosc hasla	90 dni (po uplywie wymagana zmiana)
Historia hasel	Ostatnie 12 hasel nie moze byc powtorzone
Blokada konta	Po 5 nieudanych probach logowania (odblokowanie przez IT)
Hasla domyslne	Bezwzgledny zakaz uzywania hasel domyslnych
Menedzer hasel	Rekomendowany: 1Password Business (licencje firmowe)
MFA – metoda	Authenticator app (Microsoft/Google Authenticator) lub klucz sprzet.

4.3 Dostep zdalny i VPN

Wszelki zdalny dostep do sieci firmowej i systemow wewnetrznych jest mozliwy wylacznie przez firmowy tunel VPN (Cisco AnyConnect). Polaczenie z VPN wymaga MFA. Korzystanie z niezabezpieczonych sieci publicznych (kawiarnie, hotele, lotniska) bez aktywnego VPN jest bezwzglednie zabronione.

- Instalacja klienta VPN: portal IT → "Zasoby" → "Cisco AnyConnect"
- Adres serwera VPN: vpn.lucidexis.pl (port 443)
- Split tunneling jest wylaczony – caly ruch sieciowy przechodzi przez VPN
- Sesje VPN nieaktywne przez 30 minut sa automatycznie rozlaczane
- Dostep przez VPN z krajow spoza strefy Schengen wymaga dodatkowej zgody CISO

5. BEZPIECZENSTWO URZADZEN I INFRASTRUKTURY

5.1 Urzadzenia firmowe

Wszystkie urzadzenia wydane przez Firme (laptopy, telefony, tablety) stanowia wlasnosc LUCIDEXIS i podlegaja centralnej administracji przez Dzial IT. Pracownik ponosi odpowiedzialnosc materialn za powierzone mu mienie. Zabronione jest instalowanie nieautoryzowanego oprogramowania lub usuwanie oprogramowania zainstalowanego przez IT.

Wymaganie	Laptopy Windows	MacBooki (macOS)	Telefony (iOS/Android)
Szyfrowanie dysku	BitLocker (AES-256)	FileVault 2	Wbudowane (wlaczone)
Antywirus	Microsoft Defender ATP	CrowdStrike Falcon	MDM + policy
Aktualizacje OS	Auto (patch wtorek)	Auto (Jamf)	Wymuszone przez MDM
Blokada ekranu	5 min bezczynnosci	5 min bezczynnosci	2 min bezczynnosci
Zarzadzanie	Microsoft Intune	Jamf Pro	Jamf/Intune
Lokalizacja GPS	Wlaczona (kradzjez)	Wlaczona (kradzjez)	Wlaczona (MDM)

5.2 BYOD – urzadzenia prywatne

Pracownicy moga uzywac prywatnych urzadzen do celow sluzbowych wylacznie po rejestracji w systemie MDM i akceptacji polityki BYOD. Rejestracja oznacza zgode na zdalne wyczyszczenie profilu sluzbowego w przypadku utraty urzadzenia lub rozwiazania wspolpracy. Dane sluzbowe na urzadzeniach prywatnych sa izolowane w kontenerze BYOD.

5.3 Siec firmowa i Wi-Fi

Infrastruktura sieciowa Firmy jest podzielona na segmenty (VLAN) zgodnie z klasyfikacja danych. Gosce biurowi korzystaja z oddzielnej sieci goscinnej (SSID: LUCIDEXIS-GUEST), ktora nie ma dostepu do zasobow wewnetrznych. Podlaczanie prywatnych urzadzen sieciowych (routery, switche, access pointy) do sieci firmowej jest zabronione.

- SSID: LUCIDEXIS-CORP (WPA3-Enterprise, certyfikat 802.1X) – tylko urzadzenia w MDM
- SSID: LUCIDEXIS-GUEST (WPA3-Personal) – izolowana od intranetu, dostep przez portal captive
- Porty LAN sa zabezpieczone przez 802.1X – nieautoryzowane urzadzenia sa automatycznie blokowane
- IDS/IPS (CrowdStrike Falcon) monitoruje ruch 24/7 z alertami w czasie rzeczywistym

6. OCHRONA DANYCH OSOBOWYCH (RODO)

LUCIDEXIS Sp. z o.o. przetwarza dane osobowe jako Administrator Danych Osobowych (ADO) w rozumieniu art. 4 RODO. Inspektor Ochrony Danych (IOD) – Anna Nowak – jest do dyspozycji pod adresem iod@lucidexis.pl. Podstawy prawne przetwarzania danych oraz cele przetwarzania sa okreslone w Rejestrze Czynnosci Przetwarzania (RCP), prowadzonym zgodnie z art. 30 RODO.

Obowiazki pracownikow w zakresie RODO

1. Przetwarzaj dane osobowe tylko w zakresie niezbednym do realizacji obowiazkow sluzbowych
2. Nie udostepniaj danych osobowych podmiotom nieupowaznionym ani wspolpracownikom bez potrzeby
3. Zglos naruszenie ochrony danych do IOD niezwlocznie, nie pozniej niz w ciagu 2 godzin od wykrycia
4. Przed wysylaniem danych osobowych e-mailem zaszyfruj zalaczniki (haslo podaj osobnym kanalem)
5. Nie przechowuj danych osobowych na prywatnych dyskach, chmurach lub pendrive'ach
6. Po skonczeniu pracy z dokumentami zawierajacymi dane osobowe – zniszcz wydruki w niszczarce
7. Respektuj prawa osob, ktorych dane dotycza (dostep, sprostowanie, usuniecie, przenosnosc)

Kary za naruszenie RODO

Art. 83 RODO: kary administracyjne do 20 000 000 EUR lub 4% calkowitego rocznego obr. globalnego. Art. 107 UODO: kara do 100 000 PLN lub ograniczenie/pozbawienie wolnosci do 2 lat za naruszenie przez pracownika. Firma moze dochodzic regresem od pracownika odpowiedzialnego za incydent.

7. BEZPIECZENSTWO POCZTY I KOMUNIKACJI

Poczta elektroniczna

Poczta elektroniczna jest jednym z glownych wektorow atakow (phishing, BEC, malware). Firma stosuje nastepujace mechanizmy ochrony: filtr antyspamowy (Microsoft Defender for Office 365), weryfikacja SPF/DKIM/DMARC, sandboxing zalacznikow i skanowanie linkow w czasie rzeczywistym.

- Zakaz klikania w linki lub otwierania zalacznikow z nieznanych zrodel
- Podejrzane wiadomosci nalezy przekazac na adres: phishing@lucidexis.pl (NIE otwierac)
- Zakaz uzywania firmowej skrzynki do celow prywatnych i rejestracji w serwisach niezwiazanych z praca
- Wiadomosci z danymi POUFNYMI musza byc szyfrowane (S/MIME lub zaszyfrowany zalacznik)
- Automatyczne przekierowanie firmowej poczty na prywatne adresy jest zablokowane i zabronione

Do sluzbowej komunikacji tekstowej i wideokonferencji nalezy uzywac wylacznie Microsoft Teams (licencja firmowa). Korzystanie z prywatnych komunikatorow (WhatsApp, Messenger, Telegram) do omawiania spraw sluzbowych jest zabronione. Nagrywanie spotkan w Teams wymaga poinformowania i zgody wszystkich uczestnikow.

8. ZARZADZANIE INCYDENTAMI BEZPIECZENSTWA

Definicja i klasyfikacja incydentow

Incydentem bezpieczenstwa jest kazde zdarzenie, ktore narusza lub moze naruszyc poufnosc, integralnosc lub dostepnosc informacji. Incydenty sa klasyfikowane wedlug wagi:

Poziom	Opis przykladow	Czas reakcji CISO	Eskalacja
KRYTYCZNY	Wyciek danych POUFNYCH, atak ran	< 1 godzina	Zarzad + IOD + Prawnik
WYSOKI	Phishing z klikniecia, utrata urzadze	< 4 godziny	CISO + przelozony
SREDNI	Podejrzane logowanie, naruszenie p	< 24 godziny	CISO
NISKI	Slabe haslo, brak aktualizacji	< 72 godziny	Helpdesk IT

Procedura zglaszania incydentow

1. ZAUWAZONOSC: Pracownik wykrywa lub podejrzewa incydent
2. NATYCHMIASTOWE DZIALANIE: Nie wylaczaj komputera. Odlacz od sieci (kabel lub Wi-Fi)
3. ZGLOSZENIE: Zadzwon na Hotline IT: wew. 112 (24/7) lub wyslij e-mail na security@lucidexis.pl
4. DOKUMENTACJA: Zapisz co, kiedy i jak zaobserwowales. Nie usuwaj zadnych plikow ani logow
5. WSPOLPRACA: Postepuj zgodnie z instrukcjami CISO i nie omawiaj incydentu publicznie
6. ZAMKNIECIE: CISO sporzadza raport poincydentowy i wdrazan dzialania naprawcze

Hotline Bezpieczenstwa IT

Telefon: wew. 112 (dostepny 24/7) | E-mail: security@lucidexis.pl | Komunikator: kanal #security-incidents w Microsoft Teams | Formularz zgloszeniowy: it.lucidexis.pl/incydent

9. KOPIE ZAPASOWE I CIAGLOSC DZIALANIA

Polityka kopii zapasowych

System	Czestotliwosc ba	Retencja	Lokalizacja	RTO / RPO
Bazy danych (PostgreSQL)	Co 1 godzina	30 dni	Azure + backup lokalny	4h / 1h
Pliki serwera plikow	Codziennie 22:00	90 dni	Azure Backup	8h / 24h
Poczta Exchange	Codziennie	1 rok	Microsoft 365 + Veeam	4h / 24h
Repozytorium kodu (Git)	Realtime (push)	Bezterminov	GitHub Enterprise	1h / 0
Konfiguracje sieciowe	Co tydzien	6 miesiecy	Szyfrowany dysk NAS	8h / 7 dni

Testowanie kopii zapasowych

Skutecznosc backupow jest testowana kwartalnie przez Dzial IT poprzez przetestowanie pelnego przywrocenia wybranych systemow na srodowisko testowe. Wyniki testow sa dokumentowane i archiwizowane przez CISO. Wskaznik powodzenia testow: min. 99%.

10. AUDYT I MONITOROWANIE

Wszystkie systemy informatyczne Firmy sa monitorowane 24/7 przez SIEM (Microsoft Sentinel). Logi z systemow sa przechowywane przez min. 12 miesiecy. Pracownicy sa informowani o tym, ze ich aktywnosc w systemach firmowych moze byc monitorowana w zakresie dozwolonym prawem.

Plan audytow bezpieczenstwa

Typ audytu	Czestotliwosc	Podmiot	Ostatni audyt
Przeglad uprawnien (Access Review)	Kwartalnie	CISO + HR	Pazdziernik 2024
Audyt wewnetrzny ISO 27001	Rocznie	Dzial IT + CISO	Maj 2024
Testy penetracyjne (pentest)	Rocznie	Zewnetrzna firma	Sierpien 2024
Przeglad polityk bezpieczenstwa	Rocznie lub po incyd	CISO	Styczen 2025
Skanowanie podatnosci (VA)	Miesiecznie	Narzedzie: Tenable.io	Grudzien 2024
Audyt RODO	Rocznie	IOD + zewn. audytor	Czerwiec 2024

11. SZKOLENIA I SWIADOMOSC BEZPIECZENSTWA

Skuteczna ochrona informacji wymaga swiadomych i przeszkolonych pracownikow. Program szkolen bezpieczenstwa w LUCIDEXIS obejmuje szkolenia obowiazkowe oraz dobrowolne materialy doszkalajace dostepne na platformie e-learningowej (lms.lucidexis.pl).

Szkolenie	Grupy docelowe	Czestotliwosc	Forma
Bezpieczenstwo IT – szkolenie wstepn	Nowi pracownicy	Przy zatrudnieniu	E-learning + test
RODO i ochrona danych osobowych	Wszyscy pracownicy	Rocznie	E-learning + test
Phishing – symulacje atakow	Wszyscy pracownicy	Kwartalnie	Symulacja e-mail
Zarzadzanie incydentami	Menedzerowie, IT	Rocznie	Warsztaty (4h)
Bezpieczne programowanie (OWASP)	Programisci, DevOps	Rocznie	Szkolenie + cwicz.
Cwiczenia Tabletop (BCP/DR)	Kierownictwo, CISO	Rocznie	Symulacja zdarzen

12. KARY I ODPOWIEDZIALNOSC

Naruszenie postanowien Polityki Bezpieczenstwa Informacji stanowi przewinienie dyscyplinarne i moze skutkowac konsekwencjami wynikajacymi z Kodeksu Pracy, umowy o prace lub umowy cywilnoprawnej. Firma zastrzega sobie prawo do dochodzenia odszkodowania od pracownika, jezeli jego dzialanie lub zaniechanie doprowadzilo do szkody.

- Upomnienie pisemne: pierwsze naruszenie nieumyslne niskiej wagi
- Nagana pisemna: ponowne naruszenie lub naruszenie umyslne sredniej wagi
- Rozwiazanie umowy o prace: ciezkie naruszenie, w tym umyslny wyciek danych lub sabotaz
- Powiadomienie organow scigania: naruszenia stanowiace przestepstwo (art. 287 KK, art. 107 UODO)
- Odpowiedzialnosc odszkodowawcza: art. 122 KP – pelna odpowiedzialnosc materialna za

13. HISTORIA ZMIAN

Wersja	Data	Autor	Opis zmian
1.0	01.03.2020	A. Kowalczyk	Pierwsza wersja polityki
2.0	15.01.2021	M. Jankowski	Rozszerzenie o sekcje RODO i BYOD
2.1	10.06.2021	M. Jankowski	Aktualizacja wymagan dotyczacych hasel
3.0	01.01.2023	M. Jankowski	Gruntowna przebudowa – dostosowanie do ISO 27001:2022
3.1	01.07.2024	M. Jankowski	Dodanie sekcji 5.3 (siec) i aktualizacja tabel RTO/RPO
4.0	02.01.2025	M. Jankowski	Nowe wymagania hasel (14 zn.), MFA obowiazkowe, MS Sentinel

Niniejszy dokument jest przechowywany w systemie Confluence pod sciezka: Wewnetrzne / IT / Bezpieczenstwo / PBI. Poprzednie wersje sa archiwizowane i dostepne dla upowaznionych uzytkownikow. Za aktualizacje i dystrybucje dokumentu odpowiada CISO.

Podpisy zatwierdzajace (wersja 4.0)

CISO: Michal Jankowski ..... Data: 02.01.2025

CFO: Wojciech Nowak ..... Data: 02.01.2025

CEO: Dariusz Wisniewski ..... Data: 02.01.2025